

Lecture 02: Penetration Testing

1. Cyber Crime

Cyber Crime refers to illegal activities performed using computers, networks, or digital devices where computer systems, data, or communication networks become the target or the tool of crime. Cyber crimes are offenses against computer data and systems.

Characteristics of Cyber Crime

- Uses computers or networks as attack platforms.
- Targets digital information and infrastructure.
- Can be performed remotely.
- Often crosses geographical boundaries.
- Causes financial, social, and security damage.

Types of Cyber Crime

1. Hacking

Definition

Hacking is gaining unauthorized access to a computer system, network, or application by exploiting security weaknesses.

Examples:

- Stealing passwords.
- Accessing private systems.
- Modifying system data.

2. Denial of Service (DoS) Attack

Definition

A DoS attack attempts to make a service unavailable by overwhelming the target system with excessive requests.

Effects:

- Server becomes slow.
- Legitimate users cannot access services.
- Network resources are exhausted.

3. Virus Dissemination

Definition

Virus dissemination means spreading malicious software such as viruses, worms, or malware to compromise systems.

Effects:

- Data corruption.
- Information theft.
- System damage.

4. Computer Vandalism

Definition

Computer vandalism refers to intentionally damaging, modifying, or destroying computer systems and data.

Examples:

- Website defacement.
- Deleting important files.
- Destroying databases.

5. Cyber Terrorism

Definition

Cyber terrorism involves using cyber attacks to create fear, damage critical infrastructure, or harm governments and organizations.

Targets:

- Government systems.
- Military infrastructure.
- Power grids.
- Communication systems.

6. Software Piracy

Definition

Software piracy is illegal copying, distribution, or use of software without permission from the owner.

Examples:

- Cracked software.
- Illegal software sharing.

2. Motivations Behind Cyber Attacks

An attack can be represented as:

Attack = Motive (Goal) + Method + Vulnerability

Attackers exploit weaknesses in systems to achieve their objectives.

Common Motives

1. Financial Gain

- Stealing money.
- Credit card fraud.
- Ransomware.

2. Information Theft

Stealing:

- Personal information.
- Business secrets.
- Government data.

3. Data Manipulation

Changing information for personal benefit.

Examples:

- Changing financial records.
- Modifying databases.

4. Disruption of Business

Attacking systems to stop normal operations.

5. Political or Religious Goals

Used by hacktivists or terrorist groups.

6. Military Objectives

Nation-state attackers may target:

- Defense systems.
- Intelligence information.

7. Reputation Damage

Attacking organizations to harm their public image.

8. Revenge

Employees or individuals may attack organizations due to personal conflicts.

3. Distributed Attacks

Definition

A distributed attack is an attack where multiple compromised systems participate together to attack a target. Examples:

- Botnet attacks.
- Distributed Denial of Service (DDoS).

Why Distributed Attacks Are Dangerous

- Difficult to trace attackers.
- Large attack power.
- Multiple attack sources.
- Harder defense mechanism.

4. Hacking

Definition

Hacking refers to exploiting system vulnerabilities and bypassing security controls to gain unauthorized or inappropriate access to system resources. It may involve modifying system or application features beyond their original purpose.

Goals of Hacking

Attackers may try to:

- Steal information.
- Modify data.
- Install malware.
- Gain control of systems.
- Damage organizations.

5. Types of Hackers

The lecture discusses several hacker categories.

1. Black Hat Hacker

Definition

Black hat hackers are malicious attackers who use their skills for illegal activities.

Activities:

- Data theft.
- Malware distribution.
- Unauthorized access.
- Financial fraud.

Also known as Crackers.

2. White Hat Hacker

Definition

White hat hackers are ethical security professionals who use hacking skills for defensive purposes.

They:

- Find vulnerabilities.
- Test security.
- Help organizations improve protection.

3. Gray Hat Hacker

Definition

A Gray Hat Hacker is a cybersecurity professional or individual who operates between ethical (white hat) and malicious (black hat) hacking. They may access computer systems, networks, or applications without the owner's permission to identify security vulnerabilities. Although their actions are unauthorized and may violate laws or policies, their primary intention is usually not to steal data, cause damage, or gain personal financial benefit. Instead, they often disclose the discovered vulnerabilities to the organization or the public so they can be fixed, though they may sometimes request a reward or recognition for their findings.

4. Suicide Hacker

Definition

A suicide hacker performs attacks without worrying about consequences such as punishment.

Main goal:

- Cause maximum damage.

5. Script Kiddie

Definition

A script kiddie is an inexperienced attacker who uses ready-made tools and scripts created by skilled hackers.

Characteristics:

- Limited technical knowledge.
- Depends on automated tools.

6. Cyber Terrorist

A Cyber Terrorist is an individual or organized group that uses cyberattacks, hacking techniques, and digital technologies to create fear, panic, or widespread disruption for political, ideological, religious, or social objectives. Unlike ordinary cybercriminals who are mainly motivated by financial gain, cyber terrorists aim to threaten national security, disrupt essential services, damage critical infrastructure, and influence governments or the public through fear.

Common Targets:

- Government agencies and military systems

- Critical infrastructure (power grids, water supply, transportation, healthcare, telecommunications)
- Financial institutions and banking systems
- Emergency services
- Large organizations and public institutions

7. State Sponsored Hacker

Definition

Hackers supported by governments to conduct cyber operations.

Objectives:

- Intelligence gathering.
- Military advantage.
- Espionage.

8. Hacktivist

A Hacktivist is an individual or group that uses hacking techniques to promote or support political, social, environmental, or ideological causes. Instead of seeking financial gain, hacktivists aim to raise public awareness, protest against organizations or governments, expose wrongdoing, or influence public opinion through cyber activities. While their actions are often motivated by activism, they are typically unauthorized and may be illegal.

Examples:

- Website defacement.
- Information leaks.

6. Ethical Hacking

Ethical hacking is the authorized use of hacking tools and techniques to identify vulnerabilities and improve system security. Ethical hackers simulate attacker behavior to discover exploitable weaknesses with permission from organizations.

Purpose of Ethical Hacking

1. Identify Vulnerabilities

Find security weaknesses before attackers exploit them.

2. Improve Security

Strengthen:

- Policies.
- Network protection.
- System configurations.

3. Prevent Unauthorized Access

Help organizations protect sensitive information.

Questions Ethical Hackers Try to Answer

1. What can an attacker see on the target system?
2. What can an attacker do with available information?
3. Can attacks be detected?
4. Are systems updated and patched?

5. How much effort is required for proper protection?
6. Are security measures compliant with standards?

Skills Required for Ethical Hackers

Technical Skills

- Operating systems knowledge:
 - Windows
 - Linux
 - Unix
- Networking concepts.
- Security technologies.
- Vulnerability analysis.
- Programming knowledge.

Non-Technical Skills

- Ability to learn quickly.
- Problem-solving ability.
- Communication skills.
- Strong ethics.
- Knowledge of laws and standards.

7. Hacking Terminology

Vulnerability

A vulnerability is a weakness or flaw in the design, implementation, configuration, or operation of a computer system, application, network, or security policy that can be exploited by an attacker to gain unauthorized access, compromise confidentiality, integrity, or availability, or perform malicious activities.

Examples:

- Software bugs
- Weak passwords
- Security misconfigurations
- Unpatched software
- Default credentials

Exploit

An exploit is a piece of code, software, script, or technique that takes advantage of a vulnerability in a system, application, or network to perform unauthorized actions such as gaining access, executing malicious code, stealing information, or disrupting services.

Examples:

- Buffer overflow exploit
- SQL injection exploit
- Remote code execution exploit

Payload

A payload is the component of an exploit or malware that performs the attacker's intended malicious action after a vulnerability has been successfully exploited. The payload is responsible for carrying out the actual damage or unauthorized activity on the compromised system.

Examples:

- Installing a backdoor
- Encrypting files with ransomware
- Stealing sensitive information
- Deleting or corrupting data
- Giving remote control of the system

Zero-Day Attack

A Zero-Day Attack is a cyberattack that uses a secret weakness (called a vulnerability) in software or hardware that no one knew about before. The company that made the software doesn't know about the problem yet, so they haven't created a fix or security update.

Characteristics:

- Unknown vulnerability
- No official security patch available
- Difficult to detect
- High risk and potentially severe impact

Bot

A bot is an automated software program that performs predefined tasks without continuous human intervention. While many bots are legitimate, malicious bots can be remotely controlled by attackers to perform harmful activities individually or as part of a botnet.

Examples:

- Sending spam emails
- Launching DDoS attacks
- Password guessing attacks
- Automated malware distribution

Hack Value

Hack value is how attractive or valuable something is to hackers. It shows how much benefit (like money, important data, or power) attackers can get if they successfully hack a system, network, company, or data. Systems that have valuable information or provide critical services usually have high hack value. Because of this, they are more likely to be targeted by attackers.

Examples:

- Banking databases
- Government systems
- Medical records
- Corporate intellectual property

Daisy Chaining

Daisy chaining is an attack technique in which an attacker first compromises one computer or network and then uses that compromised system as a stepping stone to gain access to additional systems within the same or connected networks. This technique helps attackers move deeper into a network while hiding their original location.

Purpose:

- Move deeper into networks
- Access protected systems
- Hide the attacker's origin
- Increase attack success

Doxing

Doxing (or doxxing) is the act of collecting, exposing, and publicly sharing an individual's personally identifiable information (PII) without their knowledge or consent. The disclosed information may include a person's home address, phone number, email address, workplace, financial details, or other private information. Doxing is typically carried out to harass, threaten, intimidate, embarrass, or harm the victim, and it can lead to serious privacy, security, and safety risks.

8. Reconnaissance**Reconnaissance**

Reconnaissance is the first phase of a cyberattack in which an attacker gathers as much information as possible about a target before attempting to compromise it. The collected information helps identify potential vulnerabilities and plan future attacks.

**Information Collected:**

- Organization details
- Employee information

- Network infrastructure
- IP addresses
- Operating systems
- Security technologies

Passive Reconnaissance

Passive reconnaissance is the process of gathering information about a target without directly interacting with its systems. Since no direct contact occurs, passive reconnaissance is difficult to detect.

Examples:

- Searching public records
- Social media research
- WHOIS lookups
- News articles
- Company websites

Active Reconnaissance

Active reconnaissance involves directly interacting with the target's systems or employees to gather information. Because it communicates with the target, active reconnaissance is more likely to be detected.

Examples:

- Network scanning
- Port scanning
- DNS queries
- Calling employees
- Banner grabbing

9. Scanning

Scanning is the phase of a cyberattack in which attackers actively examine a target network or system to identify live hosts, open ports, running services, operating systems, and security weaknesses. The information gathered helps attackers determine the best method for gaining unauthorized access.

Tools Used:

- Port scanners
- Vulnerability scanners
- Network mappers
- Ping utilities
- OS fingerprinting tools

Information Collected:

- Live hosts
- Open ports
- Operating systems
- Running services
- Device information
- Security vulnerabilities

10. Gaining Access

Gaining access is the stage of a cyberattack in which an attacker successfully obtains unauthorized access to a computer system, application, or network by exploiting vulnerabilities, stolen credentials, or security weaknesses.

Common Techniques:

- Password cracking
- SQL injection
- Buffer overflow
- Session hijacking
- Phishing
- Exploiting software vulnerabilities

Privilege Escalation

Privilege escalation is the process of increasing access rights or permissions after initially gaining access to a system. Attackers attempt to obtain administrator or root privileges so they can fully control the system, access sensitive data, disable security mechanisms, and perform additional attacks.

11. Maintaining Access

Maintaining access is the phase in which attackers establish persistent access to a compromised system so they can return later without repeating the original attack. This enables long-term control, continued surveillance, data theft, or future attacks.

Techniques:

- Backdoors
- Rootkits
- Trojans
- Hidden user accounts
- Scheduled tasks
- Startup scripts

Purpose:

- Maintain persistent access
- Steal information over time
- Launch additional attacks
- Avoid repeated exploitation

12. Covering Tracks

Covering tracks is the final phase of many cyberattacks in which attackers attempt to hide evidence of their activities to avoid detection, delay investigation, and make forensic analysis more difficult.

Methods:

- Deleting log files
- Modifying timestamps
- Clearing command history
- Removing malware traces
- Disabling monitoring tools
- Altering system records

13. Incident Management

Incident management is a structured process used by organizations to detect, analyze, contain, respond to, recover from, and document cybersecurity incidents. Its primary goal is to minimize business disruption, reduce damage, restore normal operations as quickly as possible, and improve security to prevent similar incidents in the future.

Objectives:

- Detect security incidents quickly
- Minimize operational and financial damage
- Contain and eliminate threats
- Restore affected systems and services
- Preserve evidence for investigation
- Prevent future incidents through continuous improvement

Incident Management Process

1. Preparation

Preparation involves establishing security policies, incident response plans, trained response teams, communication procedures, security tools, backups, and regular exercises so the organization is ready to respond effectively to security incidents.

2. Detection and Analysis

This phase focuses on identifying potential security incidents, confirming whether an incident has occurred, determining its type, assessing its scope and impact, and identifying the affected systems using logs, alerts, and forensic evidence.

3. Classification and Prioritization

In this phase, incidents are categorized based on their severity, impact, urgency, and affected assets so that response efforts and resources can be prioritized appropriately.

4. Notification

Notification involves informing appropriate stakeholders—including management, incident response teams, affected users, legal departments, and, when necessary, regulatory authorities—about the incident to ensure coordinated and timely response.

5. Containment

Containment aims to limit the spread and impact of the security incident by isolating affected systems, blocking malicious traffic, disabling compromised accounts, or disconnecting infected devices from the network.

6. Forensic Investigation

Forensic investigation involves collecting, preserving, and analyzing digital evidence to determine how

the attack occurred, identify the attacker's methods and source, assess the extent of the damage, and support legal or disciplinary actions if necessary.

7. Eradication and Recovery

During eradication, all malicious software, vulnerabilities, and unauthorized access mechanisms are removed from affected systems. Recovery then restores systems, data, and normal business operations while ensuring they are secure and functioning correctly.

8. Post-Incident Activities

After recovery, the organization reviews the incident to identify lessons learned, documents the response process, updates security policies, strengthens defenses, provides additional training if needed, and implements improvements to reduce the likelihood of similar incidents in the future.

14. Vulnerability Assessment

Definition

Vulnerability assessment is the examination of systems, applications, security procedures, and controls to determine weaknesses that attackers could exploit. It identifies, measures, and classifies security vulnerabilities.

Objectives

- Identify security weaknesses.
- Predict effectiveness of security controls.
- Improve protection mechanisms.

Types of Vulnerability Assessment

1. External Vulnerability Assessment

An External Vulnerability Assessment is the process of evaluating the security of an organization's Internet-facing systems, networks, and applications from an external attacker's perspective to identify vulnerabilities that could be exploited without internal access.

2. Internal Vulnerability Assessment

An Internal Vulnerability Assessment is the process of examining an organization's internal systems, networks, devices, and security controls to identify vulnerabilities that could be exploited by an insider or an attacker who has already gained access to the internal network.

3. Active Vulnerability Assessment

An Active Vulnerability Assessment is a method of identifying security vulnerabilities by actively interacting with target systems through scanning, probing, and sending requests to discover hosts, services, operating systems, open ports, and known vulnerabilities.

4. Passive Vulnerability Assessment

A Passive Vulnerability Assessment is a method of identifying security weaknesses by monitoring and analyzing existing network traffic and system activities without directly interacting with or sending requests to the target systems.

5. Application Vulnerability Assessment

An Application Vulnerability Assessment is the process of evaluating web, mobile, or desktop applications to identify security flaws, coding errors, misconfigurations, and known vulnerabilities that could be exploited by attackers.

6. Network Vulnerability Assessment

A Network Vulnerability Assessment is the process of examining an organization's network infrastructure, including routers, switches, firewalls, servers, and communication protocols, to identify vulnerabilities that could compromise the confidentiality, integrity, or availability of the network.

Methods:

1. Acquisition Phase

The Acquisition phase is the first step of the assessment process. In this phase, all necessary information and documents related to network security are collected.

Activities:

- Review laws, policies, and procedures related to network security.
- Collect and review network security documents.
- Study previous vulnerability assessment reports.
- Gather information about the existing network environment.

Purpose: To collect all required information before starting the assessment.

2. Identification Phase

The Identification phase focuses on collecting technical information about the network and identifying its components.

Activities:

- Interview network administrators, employees, and system owners.
- Gather information about routers, switches, servers, firewalls, and other network devices.
- Identify industry standards followed by the organization.

Purpose: To understand the network architecture and identify possible security weaknesses.

3. Analyzing Phase

The Analyzing phase examines the collected information to identify vulnerabilities, threats, and security risks.

Activities:

- Review previous vulnerability assessment results.
- Analyze identified vulnerabilities.
- Perform threat and risk analysis.
- Evaluate the effectiveness of existing security controls and security policies.

Purpose: To determine the security risks and identify areas that need improvement.

4. Evaluation Phase

The Evaluation phase measures the severity and impact of the identified vulnerabilities and determines appropriate security controls.

Activities:

- Determine the probability of exploiting identified vulnerabilities.
- Identify gaps between existing and required security measures.
- Recommend security controls to reduce risks.
- Identify upgrades needed for the security assessment process.

Purpose: To prioritize vulnerabilities and recommend suitable solutions.

5. Generating Reports Phase

The Generating Reports phase prepares the final vulnerability assessment report.

The report should include:

- Methods and tools used during the assessment.
- Identified vulnerabilities and findings.
- Risk analysis results.
- General and specific security recommendations.
- Information collected during all assessment phases.

All documents should be stored securely for future reference.

Purpose: To provide a complete record of the assessment and help management improve network security.

7. Host-Based Vulnerability Assessment

A Host-Based Vulnerability Assessment is the process of evaluating an individual computer, server, or endpoint device to identify vulnerabilities in its operating system, installed software, security configurations, user accounts, and file permissions.

8. Wireless Network Vulnerability Assessment

A Wireless Network Vulnerability Assessment is the process of evaluating the security of an organization's wireless networks, access points, and Wi-Fi infrastructure to identify vulnerabilities related to wireless communication, authentication, encryption, and access control that could allow unauthorized access.

Vulnerability Research

Vulnerability research is the process of discovering security weaknesses and design flaws that may allow attacks.

Importance

Helps administrators:

- Understand security trends.
- Find weaknesses.
- Prevent attacks.
- Recover from incidents.

15. Penetration Testing

Penetration testing is a security evaluation method where authorized testers simulate real attacks to identify vulnerabilities that attackers could exploit. A penetration test not only identifies vulnerabilities but also demonstrates how they can be exploited and provides a detailed report.

Why Penetration Testing is Needed

- Identify threats.
- Find exploitable vulnerabilities.
- Improve security.
- Validate security controls.
- Meet compliance requirements.
- Protect critical assets.

Types of Penetration Testing

1. Black Box Testing

Black Box Testing is a type of penetration testing where the tester has no prior knowledge about the target system or its internal structure. The tester performs the assessment from an external attacker's perspective, trying to discover vulnerabilities without any inside information. It simulates a real-world cyber attack where the attacker has limited knowledge about the target. This type of testing is also known as blind testing because the tester must gather information and identify weaknesses independently.

2. White Box Testing

White Box Testing is a type of penetration testing where the tester has complete knowledge of the target system's infrastructure and internal details. The tester is provided with information such as network architecture, source code, system configurations, and security mechanisms. This allows the tester to perform a detailed analysis and identify vulnerabilities that may not be visible from an external perspective.

3. Gray Box Testing

Gray Box Testing is a combination of Black Box and White Box Testing, where the tester has partial knowledge about the target system. The tester may receive limited information such as user credentials, network details, or application documentation. This approach provides a balance between realistic attack simulation and detailed security analysis, making it useful for identifying vulnerabilities from both an external and internal perspective.

Phases of Penetration Testing

1. Planning and Preparation Phase

The Planning and Preparation phase is the initial stage of penetration testing where the objectives, scope, and requirements of the test are defined. In this phase, the tester and organization decide the testing boundaries, select appropriate testing methodologies, and collect necessary information and permissions before starting the assessment.

2. Information Gathering Phase

The Information Gathering phase involves collecting information about the target system, network, applications, and infrastructure. This phase helps testers understand the target environment and identify possible attack points.

3. Vulnerability Analysis Phase

The Vulnerability Analysis phase focuses on identifying security weaknesses and vulnerabilities in the target system. The tester analyzes the collected information to determine possible entry points that attackers could exploit.

4. Attack Phase (Exploitation Phase)

The Attack Phase is the stage where testers attempt to exploit identified vulnerabilities to determine whether they can be successfully used by attackers. This phase demonstrates the actual impact of security weaknesses.

Activities include:

- Exploiting discovered vulnerabilities.
- Performing privilege escalation to gain higher-level access.
- Maintaining access to verify the risk level.

5. Reporting Phase

The Reporting phase is the final stage where all findings from the penetration test are documented and presented. The report explains discovered vulnerabilities, their impact, and recommendations for improving security.

Areas of Penetration Testing

Penetration testing can be performed on:

- Network.
- Web applications.
- Wireless networks.
- Firewalls.
- Routers and switches.
- Databases.
- Cloud systems.
- Mobile devices.
- Email security.
- VPN.
- IoT devices.
- Physical security.
- Social engineering.
- Source code.

Difference Between Vulnerability Assessment and Penetration Testing

Vulnerability Assessment	Penetration Testing
Finds vulnerabilities	Exploits vulnerabilities
Automated scanning	Manual testing
Identifies weaknesses	Demonstrates impact
Less intrusive	More intrusive
Regular activity	Periodic security test